

7. Determine whether the directors ensure that the institution effectively manages any outsourced internal audit function.

8. Determine whether the directors perform sufficient due diligence to satisfy themselves of the audit vendor's competence and objectivity before entering the outsourcing arrangement.

9. If the audit vendor also performs the institution's external audit or other consulting services, determine whether the institution and the vendor have discussed, determined, and documented that applicable statutory and regulatory independence standards are being met. Note - If the institution is a publicly traded company, this is a requirement of Sarbanes-Oxley. Additionally, this is a requirement of FDICIA for institutions with total assets greater than \$500 million.

10. Determine whether an adequate contingency plan exists to reduce any lapse in audit coverage, particularly coverage of high-risk areas, in the event the outsourced audit relationship is terminated suddenly.

Objective 12: Determine the extent of external audit work related to IT controls.

1. Review engagement letters and discuss with senior management the external auditor's involvement in assessing IT controls.

2. If examiners rely on external audit work to limit examination procedures, they should ensure audit work is adequate through discussions with external auditors and reviewing work papers if necessary.

Objective 13: Determine whether management effectively oversees and monitors any significant data processing services provided by technology service providers:

1. Determine whether management directly audits the service provider's operations and controls, employs the services of external auditors to evaluate the servicer's controls, or receives sufficiently detailed copies of audit reports from the technology service provider.

2. Determine whether management requests applicable regulatory agency IT examination reports.

3. Determine whether management adequately reviews all reports to ensure the audit scope was sufficient and that all deficiencies are appropriately addressed.

CONCLUSIONS

Objective 14: Discuss corrective actions and communicate findings.

1. Determine the need to perform Tier II procedures for additional validation to support conclusions related to any of the Tier I objectives.

2. Using results from the above objectives and/or audit's internally assigned audit rating or audit coverage, determine the need for additional validation of specific audited areas and, if appropriate:

- Forward audit reports to examiners working on related work programs, and
- Suggest either the examiners or the institution perform additional verification procedures where warranted.

3. Using results from the review of the IT audit function, including any necessary Tier II procedures:

- Document conclusions on the quality and effectiveness of the audit function as related to IT controls; and
- Determine and document to what extent, if any, examiners may rely upon the internal and external auditors' findings in order to determine the scope of the IT examination.

4. Review preliminary examination conclusions with the examiner-in-charge (EIC) regarding:

- Violations of law, rulings, and regulations;
- Significant issues warranting inclusion as matters requiring board attention or recommendations in the report of examination; and
- Potential effect of your conclusions on URSIT composite and component ratings.

5. Discuss examination findings with management and obtain proposed corrective action for significant deficiencies.
6. Document examination conclusions, including a proposed audit component rating, in a memorandum to the EIC that provides report-ready comments for all relevant sections of the report of examination.
7. Document any guidance to future examiners of the IT audit area.
8. Organize examination work papers to ensure clear support for significant findings and conclusions.

TIER II OBJECTIVES AND PROCEDURES

The Tier II examination procedures for the IT audit process provide additional verification procedures to evaluate the effectiveness of the IT audit function. These procedures are designed to assist in achieving examination objectives and scope and may be used entirely or selectively.

Tier II questions correspond to URSIT rating areas and can be used to determine where the examiner may rely upon audit work in determining the scope of the IT examination for those areas.

Examiners should coordinate this coverage with other examiners to avoid duplication of effort with the examination procedures found in other IT Handbook booklets.

A. MANAGEMENT

1. Determine whether audit procedures for management adequately consider:
 - The ability of management to plan for and initiate new activities or products in response to information needs and to address risks that may arise from changing business conditions;
 - The ability of management to provide reports necessary for informed planning and decision making in an effective and efficient manner;
 - The adequacy of, and conformance with, internal policies and controls addressing the IT operations and risks of significant business activities;
 - The effectiveness of risk monitoring systems;

- The level of awareness of, and compliance with, laws and regulations;
- The level of planning for management succession;
- The ability of management to monitor the services delivered and to measure the institution's progress toward identified goals in an effective and efficient manner;
- The adequacy of contracts and management's ability to monitor relationships with technology service providers;
- The adequacy of strategic planning and risk management practices to identify, measure, monitor, and control risks, including management's ability to perform self-assessments; and
- The ability of management to identify, measure, monitor, and control risks and to address emerging IT needs and solutions.

B. SYSTEMS DEVELOPMENT AND ACQUISITION

1. Determine whether audit procedures for systems development and acquisition and related risk management adequately consider:

- The level and quality of oversight and support of systems development and acquisition activities by senior management and the board of directors;
- The adequacy of the institutional and management structures to establish accountability and responsibility for IT systems and technology initiatives;
- The volume, nature, and extent of risk exposure to the institution in the area of systems development and acquisition;
- The adequacy of the institution's systems development methodology and programming standards;
- The quality of project management programs and practices that are followed by developers, operators, executive management/owners, independent vendors or affiliated servicers, and end-users;
- The independence of the quality assurance function and the adequacy of controls over program changes including the:
 - parity of source and object programming code,
 - independent review of program changes,
 - comprehensive review of testing results,
 - management's approval before migration into production, and
 - timely and accurate update of documentation;

- The quality and thoroughness of system documentation;
- The integrity and security of the network, system, and application software used in the systems development process;
- The development of IT solutions that meet the needs of end-users; and
- The extent of end-user involvement in the systems development process.

C. OPERATIONS

1. Determine whether audit procedures for operations consider:

- The adequacy of security policies, procedures, and practices in all units and at all levels of the financial institution and service providers.
- The adequacy of data controls over preparation, input, processing, and output.
- The adequacy of corporate contingency planning and business resumption for data centers, networks, service providers, and business units. Consider the adequacy of offsite data and program backup and the adequacy of business resumption testing.
- The quality of processes or programs that monitor capacity and performance.
- The adequacy of contracts and the ability to monitor relationships with service providers.
- The quality of assistance provided to users, including the ability to handle problems.
- The adequacy of operating policies, procedures, and manuals.
- The quality of physical and logical security, including the privacy of data.
- The adequacy of firewall architectures and the security of connections with public networks.

D. INFORMATION SECURITY

1. Determine whether audit procedures for information security adequately consider the risks in information security and e-banking. Evaluate whether:

- A written and adequate data security policy is in effect covering all major operating systems, databases, and applications;
- Existing controls comply with the data security policy, best practices, or regulatory

guidance;

- Data security activities are independent from systems and programming, computer operations, data input/output, and audit;
- Some authentication process, such as user names and passwords, that restricts access to systems;
- Access codes used by the authentication process are protected properly and changed with reasonable frequency;
- Transaction files are maintained for all operating and application system messages, including commands entered by users and operators at terminals, or at PCs;
- Unauthorized attempts to gain access to the operating and application systems are recorded, monitored, and responded to by independent parties;
- User manuals and help files adequately describe processing requirements and program usage;
- Controls are maintained over telecommunication(s), including remote access by users, programmers and vendors; and over firewalls and routers to control and monitor access to platforms, systems and applications;
- Access to buildings, computer rooms, and sensitive equipment is controlled adequately;
- Written procedures govern the activities of personnel responsible for maintaining the network and systems;
- The network is fully documented, including remote and public access, with documentation available only to authorized persons;
- Logical controls limit access by authorized persons only to network software, including operating systems, firewalls, and routers;
- Adequate network updating and testing procedures are in place, including configuring, controlling, and monitoring routers and firewalls;
- Adequate approvals are required before deployment of remote, Internet, or VPN access for employees, vendors, and others;
- Alternate network communications procedures are incorporated into the disaster recovery plans;
- Access to networks is restricted using appropriate authentication controls; and
- Unauthorized attempts to gain access to the networks are monitored.

2. Determine whether audit procedures for information security adequately consider compliance with the "Interagency Guidelines Establishing Standards for Safeguarding Customer Information," as mandated by Section 501(b) of the Gramm-Leach-Bliley Act of 1999. Consider evaluating whether management has:

- Identified and assessed risks to customer information;
- Designed and implemented a program to control risks;
- Tested key controls (at least annually);
- Trained personnel; and
- Adjusted the compliance plan on a continuing basis to account for changes in technology, the sensitivity of customer information, and internal/external threats to information security.

E. PAYMENT SYSTEMS

1. Determine whether audit procedures for payment systems risk adequately consider the risks in wholesale electronic funds transfer (EFT). Evaluate whether:

Adequate operating policies and procedures govern all activities, both in the wire transfer department and in the originating department, including authorization, authentication, and notification requirements;

- Formal contracts with each wire servicer exist (i.e., Federal Reserve Bank (FRB), correspondent financial institutions, and others);
- Separation of duties is sufficient to prevent any one person from initiating, verifying, and executing a transfer of funds;
- Personnel policies and practices are in effect;
- Adequate security policies protect wire transfer equipment, software, communications lines, incoming and outgoing payment orders, test keys, etc.;
- Credit policies and appropriate management approvals have been established to cover overdrafts;
- Activity reporting, monitoring, and reconciliation are conducted daily, or more frequently based upon activity;
- Appropriate insurance riders cover activity;
- Contingency plans are appropriate for the size and complexity of the wire transfer function; and
- Funds transfer terminals are protected by adequate password security.

2. Determine whether audit procedures for payment systems risk adequately consider

the risks in retail EFT (automatic teller machines, point-of-sale, debit cards, home banking, and other card-based systems including VISA/Master Charge compliance). Evaluate whether:

- Written procedures are complete and address each EFT activity;
- All EFT functions are documented appropriately;
- Physical controls protect plastic cards, personal identification number (PIN) information, EFT equipment, and communication systems;
- Separation of duties and logical controls protect EFT-related software, customer account, and PIN information;
- All transactions are properly recorded, including exception items, and constitute an acceptable audit trail for each activity;
- Reconcilements and proofs are performed daily by persons with no conflicting duties;
- Contingency planning is adequate;
- Vendor and customer contracts are in effect and detail the responsibilities of all parties to the agreement;
- Insurance coverage is adequate; and
- All EFT activity conforms to applicable provisions of Regulation E.

3. Determine whether audit procedures for payment systems risk adequately consider the risks in automated clearing house (ACH). Evaluate whether:

- Policies and procedures govern all ACH activity;
- Incoming debit and credit totals are verified adequately and items counted prior to posting to customer accounts;
- Controls over rejects, charge backs, unposted and other suspense items are adequate;
- Controls prevent the altering of data between receipt of data and posting to accounts;
- Adequate controls exist over any origination functions, including separation of data preparation, input, transmission, and reconciliation;
- Security and control exist over ACH capture and transmission equipment; and
- Compliance with NACHA, local clearinghouse, and FRB rules and regulations.

F. OUTSOURCING

1. Determine whether audit procedures for outsourcing activities adequately cover the risks when IT service is provided to external users. Evaluate whether:

- Formal procedures are in effect and staff is assigned to provide interface with users/ customers to control data center-related issues (i.e., program change requests, record differences, service quality);
- There are contracts with all customers (affiliated and nonaffiliated) and whether the institution's legal staff has approved them;
- Controls exist over billing and income collection;
- Disaster recovery plans interface between the data center, customers, and users;
- Controls exist over on-line terminals employed by users and customers;
- Comprehensive user manuals exist and are distributed; and
- There are procedures for communicating incidents to clients.

2. Determine whether audit procedures for outsourced activities are adequate. Evaluate whether:

- There are contracts in place that have been approved by the institution's legal staff,
- Management monitors vendor performance of contracted services and the financial condition of the vendor,
- Applicable emergency and disaster recovery plans are in place,
- Controls exist over the terminal used by the financial institution to access files at an external servicer's location,
- Internal controls for each significant user application are consistent with those required for in-house systems,
- Management has assessed the impact of external and internal trends and other factors on the ability of the vendor to support continued servicing of client financial institutions,
- The vendor can provide and maintain service level performance that meets the requirements of the client, and
- Management monitors the quality of vendor software releases, documentation, and training provided to clients.

Appendix B: Glossary

Application controls - Controls related to transactions and data within application systems. Application controls ensure the completeness and accuracy of the records and the validity of the entries made resulting from both programmed processing and manual data entry. Examples of application controls include data input validation, agreement of batch totals and encryption of data transmitted.

Application system - An integrated set of computer programs designed to serve a well-defined function and having specific input, processing, and output activities (e.g., general ledger, manufacturing resource planning, human resource management).

Audit charter - A document approved by the board of directors that defines the IT audit function's responsibility, authority to review records, and accountability.

Audit plan - A description and schedule of audits to be performed in a certain period of time (ordinarily a year). It includes the areas to be audited, the type of work planned, the high-level objectives and scope of the work and includes other items such as budget, resource allocation, schedule dates, and type of report issued.

Audit program - The audit policies, procedures, and strategies that govern the audit function, including IT audit.

Exposure - The potential loss to an area due to the occurrence of an adverse event.

General controls - Controls, other than application controls, that relate to the environment within which application systems are developed, maintained, and operated, and that are therefore applicable to all the applications at an institution. The objectives of general controls are to ensure the proper development and implementation of systems, and the integrity of program and data files and of computer operations. Like application controls, general controls may be either manual or programmed. Examples of general controls include the development and implementation of an IT strategy and an IT security policy, the organization of IT staff to separate conflicting duties and planning for disaster prevention and recovery.

Independence - Self-governance, freedom from conflict of interest and undue influence. The IT auditor should be free to make his or her own decisions, not influenced by the organization being audited, or by its managers and employees.

Outsourcing - The practice of contracting with another entity to perform services that might otherwise be conducted in-house. Contracted relationship with a third party to provide services, systems, or support.

Risk - The potential that events, expected or unanticipated, may have an adverse effect on a financial institution's earnings, capital, or reputation.

Risk assessment - A prioritization of potential business disruptions based on severity and likelihood of occurrence. The risk assessment includes an analysis of threats based on the impact to the institution, its customers, and financial markets, rather than the nature of the threat.

Systems Development Life Cycle (SDLC) - An approach used to plan, design, develop, test, and implement an application system or a major modification to an application